UNIVERSITE LIBRE
DE BRUXELLES

CASE STUDIES TO INTRODUCE THE NEXT CHATPER FRANCE EMPLOI – FREE - AIRBUS

2025-2026

Ch. Cuvelliez

Feb 5

FRANCE EMPLOI

TIMELINE OF THE CYBER ATTACK

France Travail Data Breach and CNIL Fine

CNIL fined *France Travail* for insufficient data security under GDPR (fine reduced to half of the maximum amount).

- A third party, *Cap Emploi*, had **excessive access to personal data without proper safeguards**.
- Around 2,300 agents of Cap employ could view personal data directly through a web browser.
- One Cap Emploi agent's account was compromised through identity impersonation: Attackers bypassed authentication by exploiting the password reset process and social engineering.

Intrusion period:

- **February 6 – March 5, 2024**…only detected after a spike in abnormal activity on February 29.
- **Exfiltrated 25 GB of data concerning approximately 36.8 million individuals** (job seekers).
- **Exposed data**: identity, contact information, employment status, start and end dates.
- **Investigation revealed multiple security weaknesses**, both related and unrelated to the breach.

FRANCE EMPLOI

WEAK PASSWORD POLICY

CNIL criticized France Travail's weak password policy.

- **Password requirements**: at least 8 characters including symbols — deemed insufficient.
- **Accounts were only locked after 50 failed login attempts**, allowing excessive brute-force possibilities.
- France Travail argued there was **no consensus on an acceptable attempt** threshold and that attackers already had valid passwords (The success of the attack does not come from weak .
- CNIL rejected this defense + it assesses security practices at the time of inspection, not just the exploited vectors.

FRANCE EMPLOI

MULTI-FACTOR AUTHENTICATION

Multi-factor authentication (MFA) is essential when access occurs from outside the internal network.

- **MFA had not been deployed for Cap Emploi accounts**, even though they accessed France Travail's systems remotely.
- The **cost and logistics of providing a second device** (often a smartphone) to all Cap Emploi employees were cited as obstacles by France Emploi
- **Responsibility for funding and implementing MFA lay with Cap Empl**oi, but within **the overall security framework defined by France Travail.**
- **MFA could have prevented or greatly hindered the attack,** as attackers would have needed the one-time codes in addition to the stolen password.
- **One-time codes did not have to rely on smartphones**; physical token devices ("small calculators") were a feasible alternative.

FRANCE EMPLOI

LOGGING AND MONITORING

Logging and Monitoring Shortcomings

- **Logging alone is insufficient**; real-time analysis is required to detect anomalies in connection data.
- **CNIL:** *France Travail* could have identified the intrusion much earlier through proper monitoring.
- **France Travail:** technical complexity of their system as a barrier to instant surveillance.
- Security Operations Centers (SOCs) exist specifically for real-time threat detection.
- Attack indicators included 25 GB exfiltration at unusual hours and abnormal error rates from legitimate accounts.
- **Excessive access rights ("open bar") for all 2,300 Cap Emploi employees** amplified the breach impact.

FRANCE EMPLOI

LOGGING AND MONITORING

Logging and Monitoring Shortcomings

- **Logging alone is insufficient**; real-time analysis is required to detect anomalies in connection data.
- **CNIL:** *France Travail* could have identified the intrusion much earlier through proper monitoring.
- **France Travail:** technical complexity of their system as a barrier to instant surveillance.
- Security Operations Centers (SOCs) exist specifically for real-time threat detection.
- Attack indicators included 25 GB exfiltration at unusual hours and abnormal error rates from legitimate accounts.
- **Excessive access rights ("open bar") for all 2,300 Cap Emploi employees** amplified the breach impact.

FRANCE EMPLOI

FINE

Key Lessons from France Travail CNIL Case

- CNIL halved maximum fine (€10M cap for state entities) despite agency budget constraints, due to sensitive data volume and observed failures.

Core principle:

- **Organizations punished for security doors left open, not just those exploited by attackers.**
- **Public sector responsibility**: Legal data protection accountability cannot be separated from technical control, even with partners.
- **Delegation limits**: Outsourcing operations (e.g., to Cap Emploi) requires verifying partner's actual security capabilities under GDPR.
- **Proportional security**: High-sensitivity/volume data (tens of millions of citizens) demands elevated protection beyond minimal/post-incident fixes.
- **Digital simplification caveat**: Interconnecting public entities for administrative ease still requires robust cybersecurity standards.

FREE

FREE MOBILE CNIL FINE OVERVIEW

- CNIL imposed a surprisingly high fine on *Free Mobile*, prompting an appeal to the Council of State.
- On October 21, 2024, Free Mobile was alerted by a hacker claiming successful system intrusion.
- Attacker first accessed the company's VPN, then its internal subscriber management tool for customer data searches.
- Breached data included personal details (identity, contacts), contract info, and IBANs for ~24.6 million contracts (19.4M mobile, 5.1M fixed).
- **CNIL investigation focused on *Free Mobile*'s GDPR security compliance, not the breach itself.**

FREE

FREE MOBILE DATA RETENTION VIOLATIONS

Failure to limit retention to time necessary for processing purposes, violating GDPR principles.

- **No system to distinguish old subscribers' data kept for 10-year accounting** from other purposes.
- **Automatic deletion after 10 years not fully functional**, leading to indefinite storage of millions of personal records.
- **Fraud prevention data declared as 5 years post-contract, but actually retained for 10 years** (misreported to CNIL).
- **System architecture made mass deletion risky, disrupting services;** purge project started 2023, targeting completion end-2025.
- Privacy policy listed separate retention periods by purpose, but systems failed to enforce them.
- 15M+ terminated contracts (>5 years old) still held, including 3M over 10 years; only 254K justified by active links.
- **Excessive retention of banking data like IBANs without proven necessity**, beyond legal accounting requirements.

FREE

FREE MOBILE VPN SECURITY DEFICIENCIES

VPN Misued

- **Attack originated via Free Mobile's VPN**, enabling remote employee access to the company's information system.

- VPN normally requires three authentication levels: **user on workstation, workstation on system, user on system.**

- CNIL criticized insufficient remote access protections, specifically lacking:
  1. **Device authentication for nomadic/mobile workstations**.
  2. **Multi-factor authentication (MFA) for users**.

- These gaps failed to meet adequate security standards for protecting remote VPN entry points.

FREE

FREE MOBILE ANOMALY DETECTION FAILURES (1/2)

Logging existed in Free Mobile's security system to record network activities for anomaly detection.

Real-time analysis lacking:

- Collected logs were not effectively monitored to identify suspicious behavior promptly.
- Surveillance of VPN, internal network, and MOBO tool deemed insufficient during CNIL inspection.
- Enabled data leak of millions of subscribers between September 28 and October 22, 2024.
- VPN used risk scoring (0-100) based on IP, third-party VPN usage, etc., but proved inadequate for threat prevention.

Post-inspection action from Free:

- Added internal network monitoring for suspicious data flows.

MOBO tool:

- Logging only on "consult" function (data access); "search" function not monitored as it allegedly didn't expose personal data but via search, consutl data were aleready offered hidden
- CNIL conclusion: Connection analysis system failed; abnormal connection volumes triggered no alerts during attack

FREE

FREE MOBILE ANOMALY DETECTION FAILURES (2/2)

- Attacker navigated internal network for nearly one month, repeatedly accessing subscriber personal data undetected.

MOBO tool vulnerability:

- Personal data exposed via browser developer tools after searches, bypassing the "consultation" function.
- Search function returned HTTP responses containing personal data, accessible without authentication through dev tools.
- This flaw enabled direct data extraction from search results, amplifying the breach scope.

FREE

FREE MOBILE DATA BREACH NOTIFICATION FAILURES (1/2)

- Inadequate notification to affected subscribers regarding the personal data breach, **violating GDPR communication obligations.**

- Email sent by Free Mobile **lacked essential details**: **measures taken, potential consequences, and protective steps for users.**

- **Free issued a general vigilance message**, claiming inability to predict all possible uses of stolen data.

GDPR requires precise information from the first message to help individuals understand the breach and mitigate risks.

- Notification listed breached data: name, first name, address, birth date/location, phone number, subscriber ID, and contract details.

FREE

FREE MOBILE DATA BREACH NOTIFICATION FAILURES (2/2)

Email to subscribers omitted key details:

- Corrective measures taken, potential breach consequences, and specific protection steps—even against unknown data misuse scenarios.
- **GDPR mandates precise information in first contact so affected individuals understand the incident nature and can act effectively to mitigate risks.**
- **Warning against fraud attempts ("fraudulent emails, SMS, calls") deemed too vague to meaningfully help** subscribers recognize and counter threats.
- Free Mobile vaguely claimed "**all necessary measures**" were taken without describing specific corrective actions in simple terms.
- CNIL stressed notifications must detail main risks and practical protective measures to reassure data subjects about effective safeguards.

FREE

FINE: WHY SO HIGH ?

Email to subscribers omitted key details:

High fine amount justified under GDPR Article 83 criteria: severity, duration, scope of violations, number affected, corrective measures, cooperation, and data nature.

Massive data exposure:

- Over 24M contracts compromised; ~15M subject to unjustified retention.
- Critical security gaps (VPN authentication, anomaly detection) enabled attack amid rising cyber threats.
- Low engagement: Only 58,239 of 24M+ contacted Free's helpline, showing ineffective communication increased subscriber risks.
- Fine set as proportionate yet dissuasive, considering Free's resources and exceptional scale (24.6M contracts affected).
- CNIL highlighted exceptional breach scope and serious non-compliance with data protection obligations.

AIRBUS

WHY RECALL?

Airbus decision challenge:

- Faced difficulty deciding to ground its A320 fleet after a software issue on a JetBlue flight (October 30).

Temporary rollback:

- Instead of immediately fixing the faulty version, Airbus reverted to the previous ELAC software version.

Second update ahead:

- Plan to reinstall a corrected version later, gradually ("au fil de l'eau").

Software role:

- The affected software controls the Elevator Aileron Computer (ELAC) — interprets pilot inputs to control pitch and roll via sensors.

Fly-by-wire system:

- ELAC acts as an intermediary between pilot and aircraft to prevent unsafe maneuvers; the A320 pioneered this technology.

AIRBUS

WHY RECALL?

Problematic version L104:

- Intended to maintain flight protections under degraded conditions (loss of sensors, computers, or hydraulics).
- Intended safety improvement: Designed to delay stall and keep aircraft within safe flight limits.

Issue discovered:

- On the JetBlue flight, version L104 caused an unexpected altitude drop.

Extra safeguard:

- L104 also introduced protection against “double failures” — simultaneous loss of two Flight Augmentation Computers (FACs) critical for stability and automatic protections.

AIRBUS

WHY RECALL?

Unexpected factor:

- Strong solar radiation interfered with flight data, causing uncontrolled elevator movements.

Extended investigation:

- Airbus discovered that rare data corruption from solar activity could push aircraft beyond structural limits or cause stalls.

Cause identified:

- Solar flares emit ionizing radiation that can corrupt electronic data.

Known phenomenon:

- Called a Single Event Effect (SEE) — when charged particles (protons or cosmic rays) hit semiconductors and disrupt operations.

Types of effects:

SET – transient voltage spike
SEU – single data bit flip
SEFI – full system interruption

AIRBUS

WHY RECALL?

Analysis required:

- Engineers examined all possible data corruption scenarios before and after such events.

Common in satellites:

- Known exposure addressed through shielding, Faraday cages, redundancy, and correction algorithms.
- Protection strategy:
- Mitigate temporary (non-permanent) effects by distributing protective measures over time.

JetBlue incident insight:

- Both ELAC flight computers were hit simultaneously — one normally controls, the other monitors.
- System limitation:
- Backup ELAC didn't take over since data corruption wasn't classified as a failure.

Design gap:

- Without a third "voting" ELAC to resolve conflicting data, the system couldn't determine which unit was wrong.
- .